

APPENDIX B.2: VENDOR SECURITY HYGIENE

VENDOR SECURITY HYGIENE	
No	Clause
1	The Proposers shall establish and maintain an information and system security program to protect TM and/or its Customer Data and Network/Systems from unauthorized access, loss, alteration, misuse, and other unintended activities or malicious threats ("Information Security Program"). TM reserves the right to terminate access to TM and/or its Customer Data and Network/Systems for any Proposers that (i) fails to implement an Information Security Program with adequate security measures, and/or (ii) where the Proposers Personnel is suspected of negligence or misuse of TM and/or its Customer Data and Network/Systems. Access termination upon TM's decision shall not mean a waiver for Proposers from its obligations of performance under the Contract and shall not give rise to any additional claims from Proposers against TM.
2	Information Security Policy The Proposers shall have documented information security policies in place to ensure the Confidentiality, Integrity, and Availability of TM and/or its Customer Data and Network/Systems at Proposers's possession.
3	Access Control Management The Proposers shall implement an appropriate access controls as the followings: - i-Assign unique access/authentication credentials to each Proposers Personnel with authorized access; - ii-Prohibit sharing of assigned access credentials; - iii-Implement password security best practices, including but not limited to complex password requirements, account lockout controls, enforcing periodic password reset, and changing all default passwords on Proposers Systems before deploying any new hardware or software; - iv-Immediately inform TM to disable access privileges to any Proposers Personnel who are terminated/resigned or no longer need such access - v-Prohibit access to TM and/or its Customer Data and Network/Systems from unauthorized devices - vi-Prohibit from storing the access credentials in any means i.e physical or in the Servers or Endpoints
4	Secure Data Handling and Transmission Where the Proposers services involve accessing, storing and/or processing of TM and/or Customer Data, the Proposers shall implement secure data handling best practices, including but not limited to: "need-to-know" and least (limited) privilege access restrictions, technical safeguards such as encryption, locked files and cabinets, and other electronic and physical security controls designed to prevent unauthorized access, misuse, loss or theft of TM Data.
5	Removable Media External removable media should not be used to view, store or transfer TM and/or Customer Data, unless there is a legitimate business need supporting the use of such devices subject to TM approval that support TM projects.
6	Encryption The Proposers shall encrypt all TM sensitive data in transit or at rest using industry-standard 256-bit encryption algorithms, disk encryptions and secure key management protocols.
7	Data Retention and Destruction If the Proposers is required to retain archival soft copies of TM and/or Customer Data for regulatory purposes, this data backup must be stored in a physically secured facility and must be stored in an encrypted format. Encryption keys must not be stored on the system storing the backup.

VENDOR SECURITY HYGIENE	
No	Clause
8	Data Retention and Destruction At TM's direction, at any time, and in any event upon termination or expiration of business agreements, except to the extent, Proposers shall immediately (or consistent with another time frame set forth by TM) return to TM or, if so directed by TM, destroy and certify the destruction of any and all TM and/or Customer Data with TM Personnel's to witness the destructions."
9	Malicious Code Prevention The Proposers shall install anti-virus, anti-malware and/or endpoint protection software with up-to-date signatures definitions on all Proposers Endpoints and/or Systems. Such as software must be properly configured to protect against all known threats, including, but not limited to: viruses, worms, Trojans, rootkits, spyware, backdoor and keystroke loggers.
10	Vulnerability Assessment and Remediation The Proposers shall perform vulnerability scans minimum every 6 month and twice a year, and assessments on all Proposers Systems used to conduct business and/or communicate with TM system, store, and remediate the identified security issues in a timely manner.
11	Vulnerability Assessment and Remediation Vulnerability with Critical and/or High severity need to be fixed or patched within one (1) month of the time vendor makes them available. The non-critical security and other patches may be applied every three (3) months. All remediation taken by Proposers must be at no additional cost to TM.
12	Vulnerability Assessment and Remediation This is implemented to Proposers's system/server that interfacing or connected to TM system
13	Configuration Management The Proposers shall maintain documented, minimum secure baseline security configuration standards (set of agreed security configuration) for Proposers Systems. This is to ensure security hardening is applied and avoid from unauthorized changes or deviations from the defined baseline. This is implemented to Proposers's system/server that interfacing or connected to TM system.
14	Logging and Security Monitoring The Proposers shall ensure that logging has been enabled with one (1) year retention period on all applicable Systems and Networking devices connected to TM system. This is to capture detailed information necessary for security incident forensic investigation.
15	Security in Application Development Where applicable to the services provided, the Proposers shall perform security testing on applications or application code provided to or developed on behalf of TM to ensure that the application or application code is secure. The Proposers shall use their standards of application security framework and/or guidelines but it must at minimum satisfy the requirements
16	Training and Awareness The Proposers shall provide ongoing training and awareness on the Information Security Program to all Proposers Personnel who have accessed to TM system.
17	Incident Response The Proposers shall have in place a security incident response plan for identifying, reporting and appropriately responding to known or suspected security incidents impacting TM and/or Customer Data and Network/Systems. In the event of a Security Breach, Proposers shall notify TM immediately after incident discovery. * Incident definition - privacy and availability
18	Incident Resolution The Propose shall perform the remediation to the incident based on the SLA defined in the Contract and shall be remediated at no additional cost to TM.